

Information Security Policy (Provisional)

Information Security Policy (Provisional)

****Organization:**** ReWrite LLC

****Owner:**** James Brady (Founder) - james@jamesbrady.org

****Review cadence:**** Annual, and upon material changes

****Scope:**** All production systems, code, data, laptops, cloud services, and third-party integrations used for Wrath Shield / EA systems.

1. Governance & Risk Management

- Maintain asset inventory (systems, data stores, secrets, endpoints).
- Quarterly risk assessment; track risks with owners and due dates.
- Security exceptions documented with time-bound approvals.

2. Access Control

- Role-based access control (RBAC) with least privilege.
- MFA required for all admin / cloud / code-hosting accounts.
- Centralized identity/SSO where supported.
- Joiner/Mover/Leaver process: provision on role, modify on change, de-provision within 24 hours of departure.
- Quarterly access reviews for production systems and secrets.

3. Data Protection

- Encryption in transit: TLS 1.2+ for all client/server and service/service traffic.
- Encryption at rest: disk and database encryption enabled for all persisted consumer or financial data.
- Secrets in environment variables or secret manager; no hard-coded secrets.
- Backups for critical data; periodic restore tests.

4. Application Security & SDLC

- Dependency scanning (npm audit / Dependabot).
- Code review required for changes to production paths.
- Logging and audit trails for production actions and admin changes.
- Vulnerability management SLAs: Critical 24-72h; High 7 days; Medium 30 days.

5. Infrastructure & Network

- Cloud security groups/firewall rules default deny; least-access egress.
- SSH or console access limited to named admins with MFA.
- Automated patching/updates for OS and base images where feasible.

6. Incident Response

Information Security Policy (Provisional)

- Detect, triage, contain, eradicate, recover; document timeline and lessons learned.
- Post-incident review with action items and owners.

7. Privacy & Compliance

- Collect minimum necessary data; honor user consent and deletion requests.
- Retention follows business/legal need; delete when no longer required.
- Publish and maintain a privacy policy for user-facing applications.

8. Vendor Management

- Assess third-party vendors for security posture; execute DPAs where applicable.
- Restrict vendor access to minimum required; review annually.

9. Training & Awareness

- Security awareness for anyone with production access; refreshed annually.

10. Business Continuity

- Define RTO/RPO targets for critical services; test restore/continuity annually.